Vulnerability Assessment Report: demo.testfire.net

Prepared for: Future Interns (Task 1)

Assessed by: Leah Padhadu

Date of Assessment: February 09, 2026

Tools Used: OWASP ZAP 2.17.0, Nmap 7.98, Browser DevTools

1. Detailed Vulnerability Findings

A. Missing Anti-CSRF Tokens

Description: No Anti-CSRF tokens were found in the HTML submission forms.

Impact: Cross-Site Request Forgery (CSRF) allows an attacker to force a victim to send an HTTP request to a target destination without their knowledge or intent. This exploits the trust a website has for a user.

Risk Scenarios: The attack is effective if the victim has an active session or is on the same local network as the target.

Solution:

Architecture: Use a vetted library like OWASP CSRFGuard.

Implementation: Generate a unique, unpredictable nonce for each form and verify it upon receipt.

Best Practice: Do not use the GET method for any request that triggers a state change.

B. Missing Content Security Policy (CSP)

Description: The site lacks a CSP header, which is an added layer of security to detect and mitigate XSS and data injection attacks.

Function: CSP allows owners to declare approved sources of content (JavaScript, CSS, fonts, images).

Solution: Configure the web/application server to set the Content-Security-Policy header.

C. Missing Anti-Clickjacking Protection

Description: The response does not include X-Frame-Options or CSP frame-ancestors.

Impact: This allows "ClickJacking" attacks, where the site can be framed by a malicious domain to trick users into performing actions.

Solution: Use the SAMEORIGIN or DENY directive on all web pages.

D. Insecure Cookie Configuration (SameSite)

Solution: The JSESSIONID cookie was set without the SameSite attribute.

Impact: The cookie can be sent in "cross-site" requests, making the site vulnerable to CSRF and timing attacks.

Solution: Set the SameSite attribute to 'Lax' or 'Strict' for all cookies.

E. Information Leakage (Server Header)

Description: The server leaks version information via the "Server" header (Apache-Coyote/1.1).

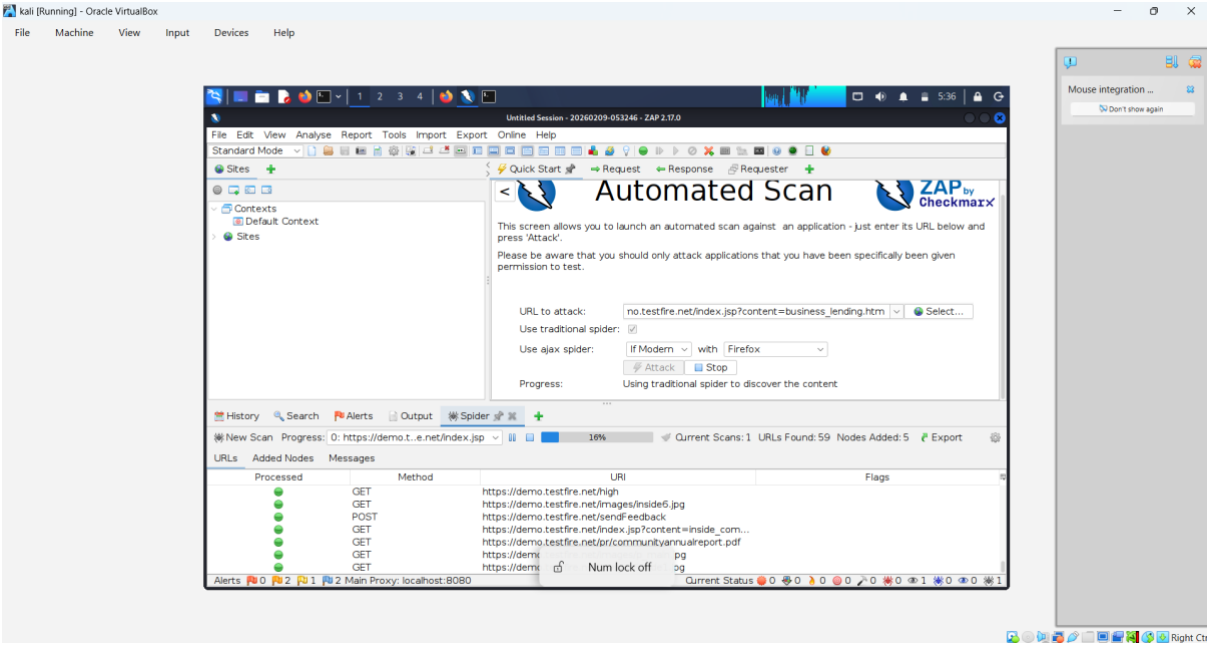
Impact: This facilitates attackers in identifying specific vulnerabilities related to that server version.

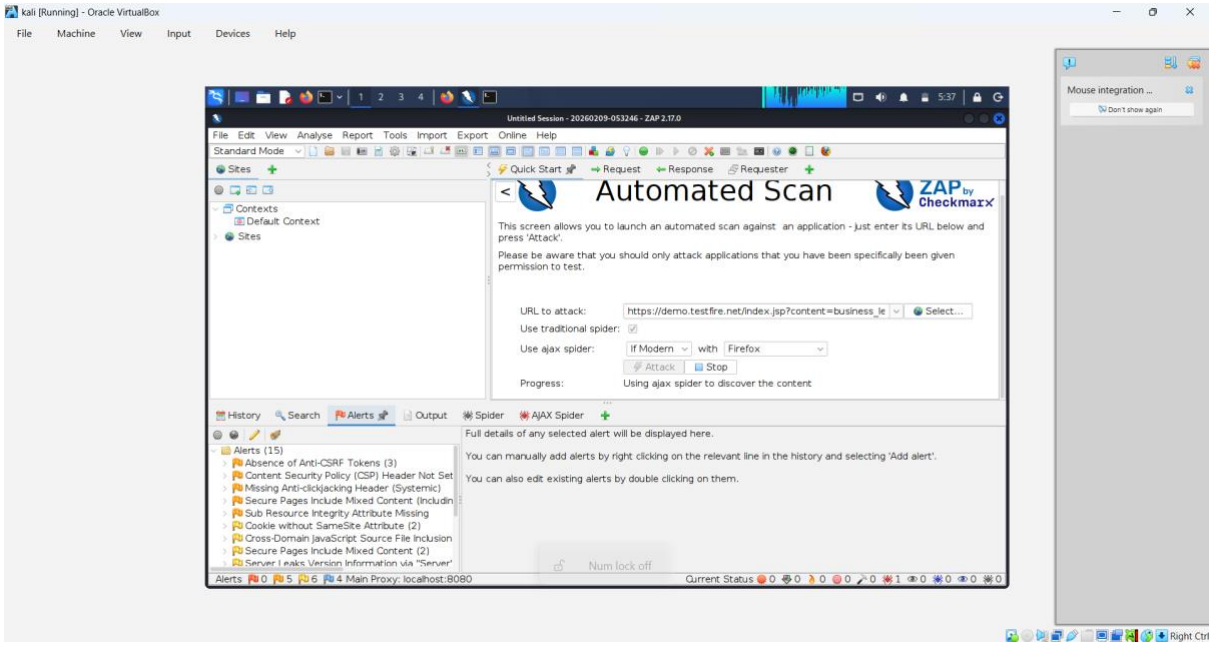
Solution: Configure the server to suppress the "Server" header or provide generic details.

F. Third-Party Script Inclusion

Description: The page includes script files from third-party domains.

Solution: Ensure JavaScript source files are loaded only from trusted sources.




kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Untitled Session - 20260209-053246 - ZAP 2.17.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
Automated Scan
ZAP by Checkmarx
This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'.
Please be aware that you should only attack applications that you have been specifically been given permission to test.
URL to attack:
https://demo.testfire.net/index.jsp?content=business_le
Select...
Use traditional spider:
Use ajax spider:
If Modern
with
Firefox
Attack
Stop
Progress:
Using ajax spider to discover the content
History
Search
Alerts
Output
Spider
AJAX Spider
Alerts (15)
Absence of Anti-CSRF Tokens (3)
Content Security Policy (CSP) Header Not Set
Missing Anti-clickjacking Header (Systemic)
Secure Pages Include Mixed Content (Includin
Sub Resource Integrity Attribute Missing
Cookie without SameSite Attribute (2)
Cross-Domain JavaScript Source File Inclusion
Secure Pages Include Mixed Content (2)
Server Leaks Version Information via "Server"
Full details of any selected alert will be displayed here.
You can manually add alerts by right clicking on the relevant line in the history and selecting 'Add alert'.
You can also edit existing alerts by double clicking on them.
Num lock off
Alerts 0 5 6 4 Main Proxy: localhost:8080
Current Status 0 0 0 0 0 0 1 0 0 0 0
Mouse integration ...
Don't show again
Right Ctrl

NMAP Scan

1. Technical Data Decoding & Reconnaissance

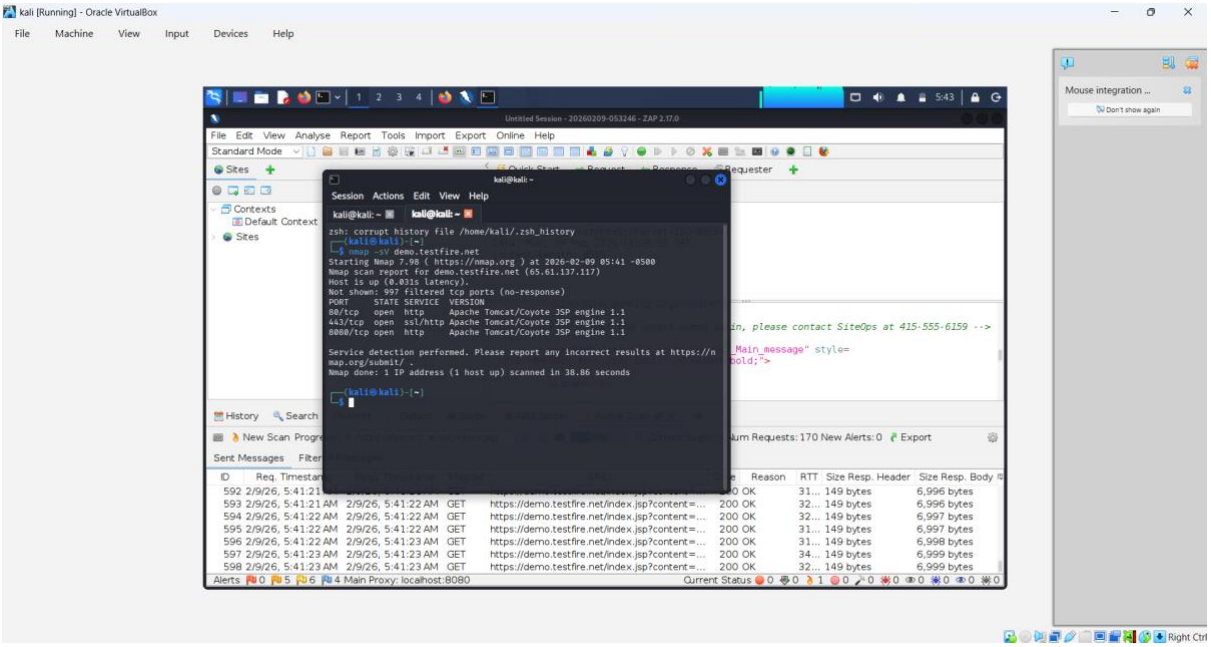
Analysis of the provided network logs and screenshots reveals the following infrastructure details:

Infrastructure Fingerprinting: The server is identified as Apache Tomcat/Coyote JSP engine 1.1. This specific version string is leaked through the "Server" HTTP response header.

Port & Service Status: Nmap scanning confirmed three open ports: 80/tcp (HTTP), 443/tcp (HTTPS), and 8080/tcp (HTTP-Proxy).

Session Management: The application uses a JSESSIONID cookie (e.g., 13CDE03636311084E889D80AE7F7F434) for session tracking.

Document Standards: The application is rendered in "Almost Standards Mode" due to the absence of a modern <!DOCTYPE html> declaration. This can cause inconsistent browser behavior and potential security bypasses in older environments.



3. Tooling & Maintenance Observations

Outdated Scanner: The version of OWASP ZAP (2.17.0) used for this audit is flagged as out of date and no longer receiving updates.

Solution: To ensure the highest accuracy in future tests, download the latest version from zaproxy.org.

4. Conclusion

The assessment of demo.testfire.net identifies a high-risk security posture primarily driven by the lack of modern session protections (CSRF tokens and SameSite attributes) and defensive headers (CSP and X-Frame-Options). Immediate remediation is recommended to prevent session hijacking and UI redressing attacks.